Paradox: KI für vertrauliche Dokumente

Informationen für IT-Abteilung und Datenschutz

Stand: Oktober 2026
najjar961.github.io/paradox

Paradox ist ein KI-Assistent, mit dem Mitarbeitende Dokumente fragen, zusammenfassen, bearbeiten, schwärzen und vergleichen können, **ohne dass Dokumente an einen Cloud-Anbieter gehen oder gespeichert werden**. Das Modell läuft auf dem eigenen Gerät oder dem eigenen Server. Der Quellcode ist offen (AGPL-3.0) und jede Aussage in diesem Blatt lässt sich nachprüfen.

Zwei Betriebsarten

	Paradox Lite (im Browser)	Selbst gehostet (eigener Server)
Wo läuft die KI?	Auf der Grafikkarte des Arbeitsplatzrechners (WebGPU)	Auf Ihrem Server, mit Ollama im selben Docker-Netz
Wo liegen die Dokumente?	Nur im Arbeitsspeicher des Browser-Tabs	Nur im Arbeitsspeicher des Servers, pro Anmeldesitzung
Wann werden sie gelöscht?	Beim Schließen des Tabs oder per Klick	Abmelden, 30 Min. Inaktivität, max. 8 Std., Neustart
Was geht ins Internet?	Nur einmaliger Download der App und öffentlicher KI-Modelle. Kein Upload.	Nichts, nach dem Download der Modelle (auch ohne Internet betreibbar)
Installation	Keine. Optional: die statischen Dateien im Intranet hosten	docker compose, Konten per Datei mit bcrypt-Hashes

Datenschutz (DSGVO)

- **Kein Dienstleister verarbeitet Dokumente.** Bei Paradox Lite und bei selbst gehostetem Betrieb mit lokalem Modell bleiben alle Inhalte im Unternehmen. Dokumentinhalte werden weder an Dritte noch in Drittländer übermittelt.
- **Speicherbegrenzung und Datenminimierung** (Art. 5 DSGVO): keine Datenbank, keine Dateien, keine Inhalte in Logs. Daten existieren nur, solange sie benutzt werden.
- **Schwärzen eingebaut:** Namen, Adressen, IBANs, Ausweisnummern werden wirklich aus PDF, Word, Excel und PowerPoint entfernt, inklusive Autor und Metadaten.
- **Optionale Cloud-Modelle** (OpenAI, Anthropic) sind standardmäßig aus. Wer sie einschaltet, braucht dafür die üblichen Verträge (AVV).

Technische Maßnahmen (Art. 32 DSGVO)

- Content-Security-Policy: Der Browser blockiert jede Verbindung außer zur App und zu den Modell-Servern
- Keine Browser-Speicherung von Inhalten (kein localStorage, kein IndexedDB)
- Container mit schreibgeschütztem Dateisystem, Zwischenspeicher nur im RAM, alle Capabilities entzogen
- bcrypt-Passwörter, Begrenzung von Anmeldeversuchen, CSRF-Schutz, HttpOnly/SameSite-Cookies, HSTS
- Strikte Trennung der Sitzungen; Schutz gegen Prompt-Injection aus Dokumenten
- Automatische Tests bei jeder Änderung, auch: „nichts wird auf die Festplatte geschrieben“

In 5 Minuten selbst prüfen

- Entwicklertools (F12) → Netzwerk: Beim Hochladen und Fragen wird keine Anfrage mit dem Dokument gesendet.
- WLAN ausschalten und die Seite neu laden: Paradox Lite arbeitet weiter.
- Entwicklertools → Anwendung → Speicher: kein Dokument und kein Chat gespeichert.
- Server: `docker compose exec paradox touch /srv/test` → „Read-only file system“.

Grenzen, ehrlich benannt

- Paradox schützt nicht vor Schadsoftware oder Browser-Erweiterungen auf dem Arbeitsplatz.
- Beim Laden der App und der Modelle sehen GitHub und Hugging Face die IP-Adresse. Abhilfe: App und Modelle intern bereitstellen.
- KI kann sich irren. Antworten nennen Quellen; Änderungen und Schwärzungen zeigen vorher eine Vorschau der echten Datei.
- Lite braucht Chrome oder Edge und eine Grafikkarte mit einigen GB Speicher.

Einführung

- **Sofort testen:** najjar961.github.io/paradox/app
- **Selbst hosten:** github.com/najjar961/paradox (Anleitung im README)
- **Sicherheitsseite:** najjar961.github.io/paradox/security.html
- **Installation und Support für Ihr Unternehmen:** X / Twitter @paradoxexe404